

CERTIFICATO ANALISI DEL RISCHIO GDPR

Cliente: Soluzioni Salute Informatica S.r.l. (Welmed)

Data: 3 giugno 2026



Conformità adeguata. Monitoraggio periodico e aggiornamento annuale della documentazione.

Matrice Dettagliata dei Rischi

ID	Rischio	Prob. (1-4)	Impatto (1-4)	Score (0-100)	Livello
R1	Assenza Piano BC&DR — Disastro IT / Indisponibilità piattaforma	1.30	2.95	24	BASSO
R2	Registro Trattamenti obsoleto o incompleto (dati sanitari pazienti)	1.95	2.21	27	BASSO

R3	DPIA insufficiente — piano d'azione vuoto per trattamenti ad alto rischio	1.80	2.10	24	BASSO
R4	Informativa privacy/consenso digitale non aggiornata (AI, profilazione)	1.95	2.21	27	BASSO
R5	Assenza Registro Violazioni e procedura notifica Garante 72h (art. 33)	1.31	1.49	12	BASSO
R6	DPA con fornitori cloud/SaaS non verificati (AWS, Twilio, Mailchimp...)	1.33	2.25	19	BASSO
R7	Formazione GDPR e cybersecurity insufficiente per operatori sanitari	2.00	1.50	19	BASSO
R8	AI Act — classificazione e conformità sistema AIDA incerta	1.20	1.75	13	BASSO
R9	Cookie Policy non conforme (Provvedimento Garante 10/06/2021)	1.20	1.05	8	BASSO
R10	Data breach dati sanitari — accesso non autorizzato a cartelle cliniche	1.89	2.89	34	MEDIO
R11	Attacco ransomware — cifratura dati e blocco piattaforma di telemedicina	1.33	3.00	25	BASSO
R12	Intercettazione sessioni video/audio di teleconsulto (man-in-the-middle)	1.20	2.80	21	BASSO
R13	Accesso non autorizzato tramite credenziali compromesse / phishing	2.10	2.71	36	MEDIO
R14	Vulnerabilità API non protette — esposizione endpoint dati pazienti	1.80	2.10	24	BASSO
R15	Attacco DDoS — indisponibilità piattaforma durante visite programmate	1.20	2.10	16	BASSO
R16	Errore diagnostico/terapeutico mediato da AI — liability clinica	1.20	2.80	21	BASSO
R17	Interruzione servizio durante emergenza medica — danno al paziente	1.60	3.40	34	MEDIO
R18	Identificazione errata del paziente (identity mismatch) — prescrizione/referto sbagliato	1.20	2.80	21	BASSO
R19	Responsabilità civile per malfunzionamento piattaforma durante visita	2.00	3.50	44	MEDIO
R20	Assenza o invalidità del consenso informato digitale al teleconsulto	1.80	2.10	24	BASSO